

Credential Hunting in Windows

Once we have access to a target Windows machine through the GUI or CLI, we can significantly benefit from incorporating credential hunting into our approach. **Credential Hunting** is the process of performing detailed searches across the file system and through various applications to discover credentials. To understand this concept, let's place ourselves in a scenario. We have gained access to an IT admin's Windows 10 workstation through RDP.

Search Centric

Many of the tools available to us in Windows have search functionality. In this day and age, there are search-centric features built into most applications and operating systems, so we can use this to our advantage on an engagement. A user may have documented their passwords somewhere on the system. There may even be default credentials that could be found in various files. It would be wise to base our search for credentials on what we know about how the target system is being used. In this case, we know we have access to an IT admin's workstation.

What might an IT admin be doing on a day-to-day basis & which of those tasks may require credentials?

We can use this question & consideration to refine our search to reduce the need for random guessing as much as possible.

Key Terms to Search

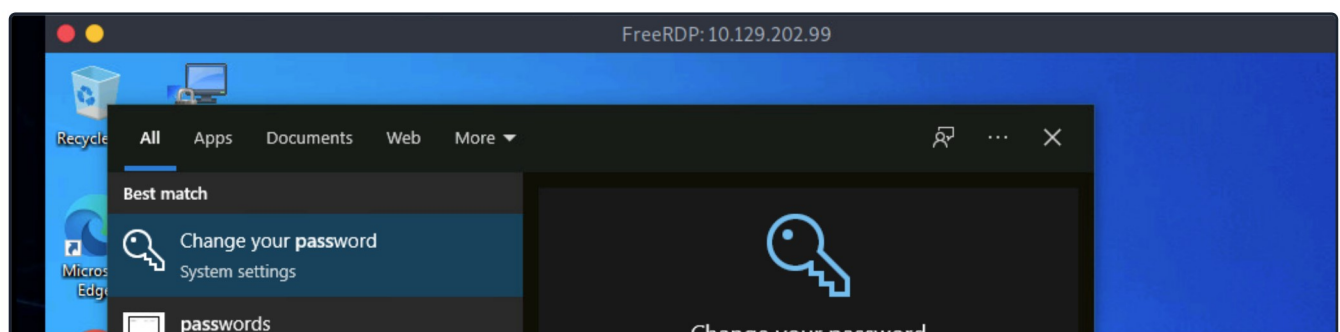
Whether we end up with access to the GUI or CLI, we know we will have some tools to use for searching but of equal importance is what exactly we are searching for. Here are some helpful key terms we can use that can help us discover some credentials:

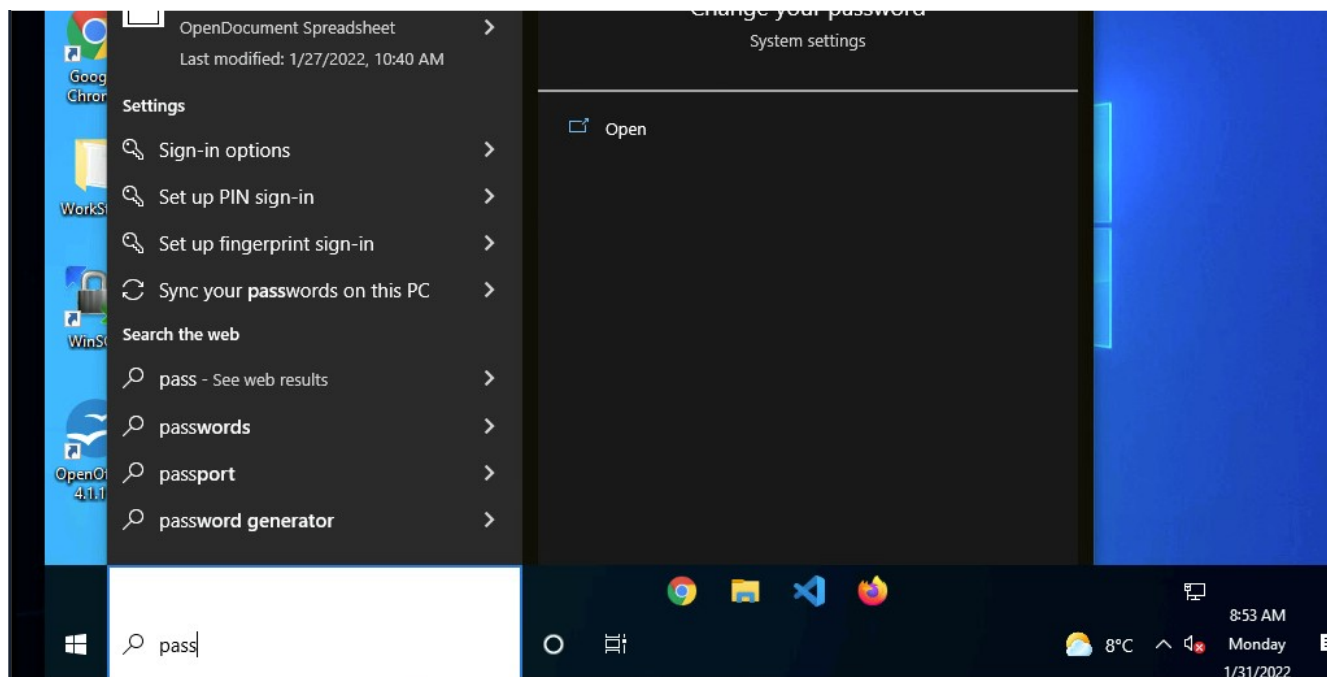
Passwords	Passphrases	Keys
Username	User account	Creds
Users	Passkeys	Passphrases
configuration	dbcredential	dbpassword
pwd	Login	Credentials

Let's use some of these key terms to search on the IT admin's workstation.

Search Tools

With access to the GUI, it is worth attempting to use **Windows Search** to find files on the target using some of the keywords mentioned above.





By default, it will search various OS settings and the file system for files & applications containing the key term entered in the search bar.

We can also take advantage of third-party tools like [Lazagne](#) to quickly discover credentials that web browsers or other installed applications may insecurely store. It would be beneficial to keep a [standalone copy](#) of Lazagne on our attack host so we can quickly transfer it over to the target. [Lazagne.exe](#) will do just fine for us in this scenario. We can use our RDP client to copy the file over to the target from our attack host. If we are using [xfreerdp](#) all we must do is copy and paste into the RDP session we have established.

Once Lazagne.exe is on the target, we can open command prompt or PowerShell, navigate to the directory the file was uploaded to, and execute the following command:

Running Lazagne All

Credential Hunting in Windows

```
C:\Users\bob\Desktop> start lazagne.exe all
```

This will execute Lazagne and run [all](#) included modules. We can include the option [-vv](#) to study what it is doing in the background. Once we hit enter, it will open another prompt and display the results.

Lazagne Output

Credential Hunting in Windows

```
=====
|                                     |
|                                     |
|               The LaZagne Project  |
|                                     |
|               ! BANG BANG !        |
|                                     |
|=====|

##### User: bob #####

----- Wincsp passwords -----

[+] Password found !!!
URI : 10.129.202.51
```

```
user: root@kali:~$ cat /etc/passwd
Login: admin
Password: SteveisReallyCool123
Port: 22
```

If we used the `-vv` option, we would see attempts to gather passwords from all Lazagne's supported software. We can also look on the GitHub page under the supported software section to see all the software Lazagne will try to gather credentials from. It may be a bit shocking to see how easy it can be to obtain credentials in clear text. Much of this can be attributed to the insecure way many applications store credentials.

Using findstr

We can also use `findstr` to search from patterns across many types of files. Keeping in mind common key terms, we can use variations of this command to discover credentials on a Windows target:

Credential Hunting in Windows

```
C:\> findstr /SIM /C:"password" *.txt *.ini *.cfg *.config *.xml *.git *.ps1 *.yaml
```

Additional Considerations

There are thousands of tools & key terms we could use to hunt for credentials on Windows operating systems. Know that which ones we choose to use will be primarily based on the function of the computer. If we land on a Windows Server OS, we may use a different approach than if we land on a Windows Desktop OS. Always be mindful of how the system is being used, and this will help us know where to look. Sometimes we may even be able to find credentials by navigating and listing directories on the file system as our tools run.

Here are some other places we should keep in mind when credential hunting:

- Passwords in Group Policy in the SYSVOL share
- Passwords in scripts in the SYSVOL share
- Password in scripts on IT shares
- Passwords in web.config files on dev machines and IT shares
- unattend.xml
- Passwords in the AD user or computer description fields
- KeePass databases --> pull hash, crack and get loads of access.
- Found on user systems and shares
- Files such as pass.txt, passwords.docx, passwords.xlsx found on user systems, shares, [Sharepoint](#)

You have gained access to an IT admin's Windows 10 workstation and begin your credential hunting process by searching for credentials in common storage locations.

Connect to the target and use what you've learned to discover the answers to the challenge questions.

VPN Servers

 **Warning:** Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

● UDP 1337 ● TCP 443

[DOWNLOAD VPN CONNECTION FILE](#)**Connect to Pwnbox**

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

45ms ▼

Terminate Pwnbox to switch location

[Start Instance](#)

∞ / 1 spawns left

Waiting to start...

**Questions**

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)

🧑‍🔧 RDP to with user "Bob" and password "HTB_@cademy_stdnt!"

+ 0 📦

What password does Bob use to connect to the Switches via SSH? (Format: Case-Sensitive)

Submit your answer here...

[Cheat Sheet](#)[Download VPN
Connection File](#)

+10 Streak pts

🚩 Submit

📖 Show Solution

RDP to with user "Bob" and password "HTB_@cademy_stdnt!"

+ 0 What is the GitLab access code Bob uses? (Format: Case-Sensitive)

Submit your answer here...

+10 Streak pts

Submit

Show Solution

RDP to with user "Bob" and password "HTB_@cademy_stdnt!"

+ 0 What credentials does Bob use with WinSCP to connect to the file server? (Format: username:password, Case-Sensitive)

Submit your answer here...

+10 Streak pts

Submit

Hint

Show Solution

RDP to with user "Bob" and password "HTB_@cademy_stdnt!"

+ 1 What is the default password of every newly created Inlanefreight Domain user account? (Format: Case-Sensitive)

Submit your answer here...

+10 Streak pts

Submit

Hint

Show Solution

RDP to with user "Bob" and password "HTB_@cademy_stdnt!"

+ 1 What are the credentials to access the Edge-Router? (Format: username:password, Case-Sensitive)

Submit your answer here...

+10 Streak pts

Submit

Hint

Show Solution

← Previous

Next →

Cheat Sheet

Resources

? Go to Questions

Table of Contents

Introduction

Theory of Protection



Credential Storage



John The Ripper



Remote Password Attacks

Network Services



 Password Mutations



 Password Reuse / Default Passwords



Windows Local Password Attacks

 Attacking SAM



 Attacking LSASS



 Attacking Active Directory & NTDS.dit



 [Credential Hunting in Windows](#)

Linux Local Password Attacks

 Credential Hunting in Linux

 Passwd, Shadow & Opasswd

Windows Lateral Movement

 Pass the Hash (PtH)

 Pass the Ticket (PtT) from Windows

 Pass the Ticket (PtT) from Linux

Cracking Files

 Protected Files

 Protected Archives

Password Management

Password Policies

Password Managers

Skills Assessment

 Password Attacks Lab - Easy

 Password Attacks Lab - Medium

 Password Attacks Lab - Hard

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left